

ResolvX

Root Cause Analysis Policy

Topic-Specific Policy - Corrective Action Rigor & Recurrence Prevention

POL-017 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-017
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	GRC Lead
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Frameworks	ISO 27001:2022 Clause 10.1, 10.2 · NIST CSF 2.0 ID.IM · SOC 2 CC4.2

1. Purpose

This Root Cause Analysis Policy establishes how ResolvX determines the actual cause of a control deficiency so that corrective action prevents recurrence rather than papering over the same finding a second time.

The Corrective Action Plan register already captures a root cause for every finding. This policy defines the method used to arrive at that entry, so its quality doesn't depend on who happened to fill it in that day and adds the recurrence and effectiveness checks that turn a documented root cause into an actual prevented repeat.

2. Scope

This policy applies to every item logged in the Corrective Action Plan register, regardless of source:

- Internal audit findings.
- External audit findings (SOC 2, ISO 27001).
- Control deficiencies identified through any POL-0XX policy's Compliance and Enforcement section.
- Post-incident review findings (per POL-015 §8).
- Vendor risk assessment findings (per POL-005).

3. Root Cause vs. Immediate Cause

An immediate cause describes what happened. A root cause describes why the organisation's controls allowed it to happen and stopping at the immediate cause is the most common way a corrective action fails to prevent recurrence.

Level	Example (Snyk finding open past SLA)
Symptom (what was observed)	Two High-severity Snyk findings remained open beyond the 30-day SLA.
Immediate cause (what directly caused it)	The findings were not triaged or assigned to an owner when detected.
Root cause (why the immediate cause was possible)	No dedicated vulnerability management process existed at the time so the triage depended on an individual noticing the alert, not a defined workflow.

A corrective action that only re-triages the two specific findings address the symptom. A corrective action that establishes the ongoing triage workflow, as POL-010 now does, addresses the root cause.

4. Methodology

4.1 Standard Method - Five Whys

Every CAP item receives, at minimum, a Five Whys analysis: starting from the observed symptom, ask "why did this happen" repeatedly, typically five times, though the actual number is whatever it takes to reach an organisational cause (a missing process, an undefined ownership, an absent control) rather than stopping at an individual's specific action. "An engineer missed the alert" is rarely a root cause; "there was no defined process for what happens when the alert fires" usually is.

4.2 Extended Method - Categorical Analysis

For Critical findings and any repeat finding (§5), Five Whys is supplemented with a categorical review across four dimensions, to catch causes that a single causal chain can miss:

- People - was the right role assigned, trained, and aware of the requirement?
- Process - did a defined process exist, and was it followed?
- Technology - did tooling support the requirement, or did the control depend on manual diligence?
- External - did a vendor, regulatory change, or third-party dependency contribute?

5. Repeat Findings

A second CAP finding tracing to the same root cause within 12 months of the first is not treated as routine, it means the original corrective action didn't actually address the cause. A repeat finding is automatically escalated to the CISO, requires the categorical analysis in §4.2 regardless of the finding's individual severity, and is reported as a distinct item in the next quarterly risk report under POL-014.

6. Effectiveness Verification

Closing a CAP item once the corrective action is implemented confirms the fix was applied but it does not confirm the fix worked. The Corrective Action Plan Register's Verification Method and Verification Notes fields are completed in two stages, not one:

Stage	Confirms	Timing
Implementation verification	The corrective action described was actually put in place	At the point of closure
Effectiveness verification	The root cause has not produced a repeat finding	One full quarterly review cycle after closure, minimum

A CAP item is not considered fully closed until both stages are complete, thus implementation alone leaves open the possibility that the fix looked right but didn't actually address the cause identified in §3.

7. Thematic Review

Individual root causes sometimes share a common thread across otherwise unrelated. This policy formalises that practice: GRC Lead reviews the full CAP register for thematic clustering as part of the quarterly risk report under POL-014, rather than relying on it being noticed opportunistically.

8. Roles & Responsibilities

8.1 GRC Lead

- Owns this policy and the Corrective Action Plan register.
- Confirms every CAP item includes a Five Whys analysis before closure, and a categorical analysis where required (§4.2).
- Runs the thematic review (§7) and tracks effectiveness verification timing (§6).

8.2 Finding Owner

- Conducts the root cause analysis for findings assigned to them, with GRC Lead's guidance.
- Implements the corrective action addressing the identified root cause, not only the symptom.

8.3 CISO

- Receives escalation for every repeat finding (§5).

9. Compliance and Enforcement

A CAP item closed without a documented root cause analysis or closed at implementation verification without the follow-up effectiveness verification in §6, is itself logged as a control deficiency.

10. Document Control

Policy ID	POL-017
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	GRC Lead
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 Clause 10.1, 10.2 · NIST CSF 2.0 ID.IM · SOC 2 TSC CC4.2
Related Documents	POL-005 (Vendor Management Policy), POL-014 (Risk Management Policy), POL-015 (Incident Management Policy), Corrective Action Plan register

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		